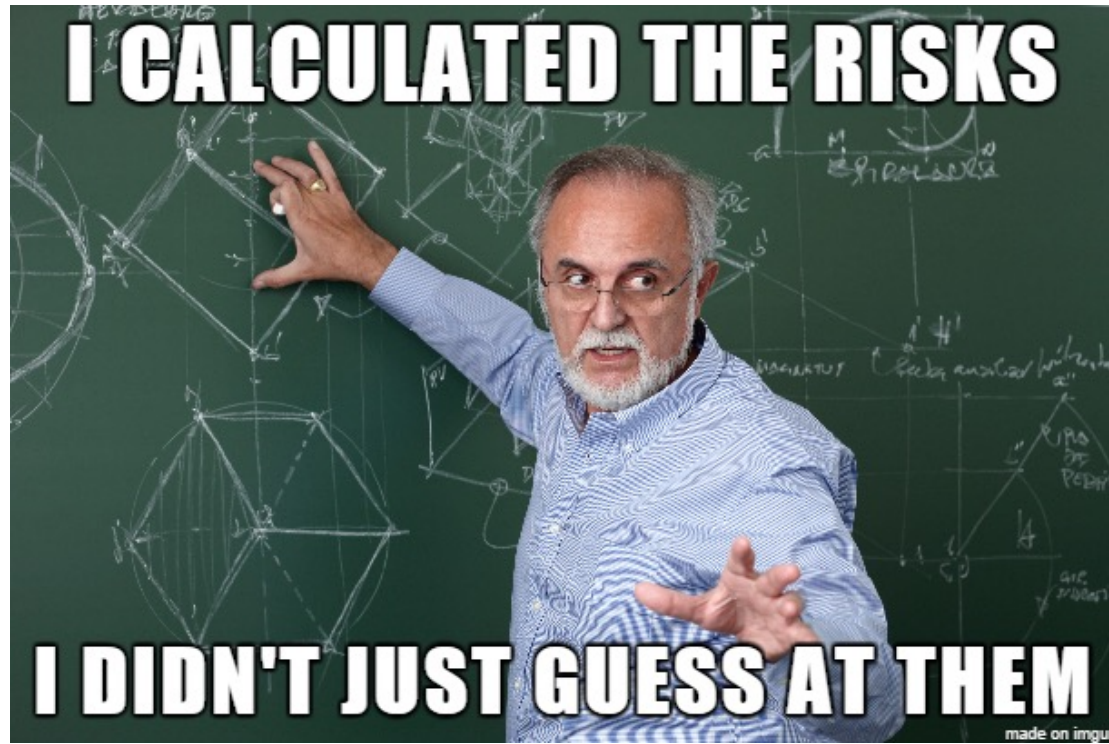


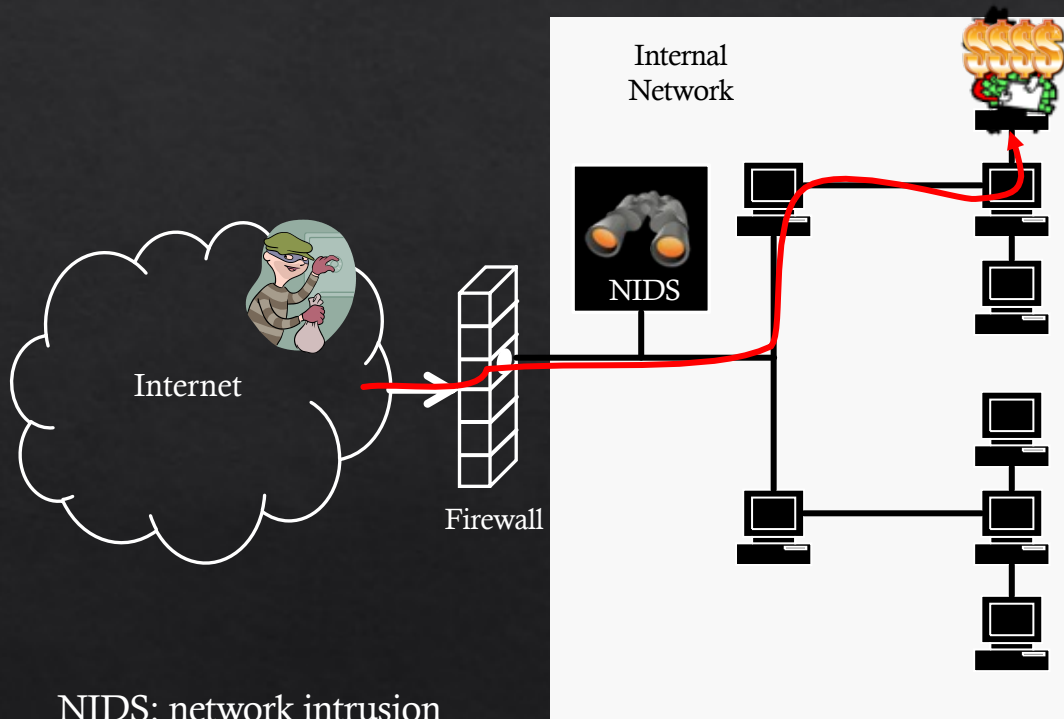


9. Security Modelling and Analysis

Jin Hong

jin.hong@uwa.edu.au

How secure is my system/network?



NIDS: network intrusion
detection system



IT Security Management

- ◇ Related tasks for IT security management include
 - ◇ Specification of security objectives, strategies and policies
 - ◇ Determine organisational IT security requirements
 - ◇ Security threat assessments of IT assets and risks
 - ◇ Specification of appropriate security methods
 - ◇ Implementation and maintenance of security methods
 - ◇ Security awareness program and adoption
 - ◇ Detection and prevention of security incidents

Security Assessment

- ◆ Some key questions to answer in security assessment are:
 - ◆ How to represent and capture various **attack scenarios**?
 - ◆ What kinds of attacks are applicable?
 - ◆ How can these attacks be carried out?
 - ◆ How do we measure their impact on the system?
 - ◆ How to select the **best security solutions** and controls?
 - ◆ What is the best security practice for the given attack scenario?
 - ◆ What is the best security solution given these constraints?

Security Assessment

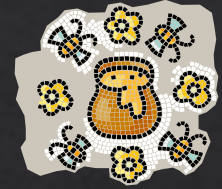
- ◇ Three main approaches
 - ◇ Test on a real network
 - ◇ Test on a duplicated real network
 - ◇ E.g., Emulation
 - ◇ Model-based Security Assessment
- ◇ etc

Use of Security Models

- ◇ Security models can be used to provide a **systematic approach** to assess the security of systems
- ◇ Security models are one aspect of the security assessment, which requires 3M
 - ◇ **Security Measures** : To collect required information
 - ◇ **Security Metrics** : To represent the analysis results
 - ◇ **Security Models** : To capture security information of the system

Security Measurement

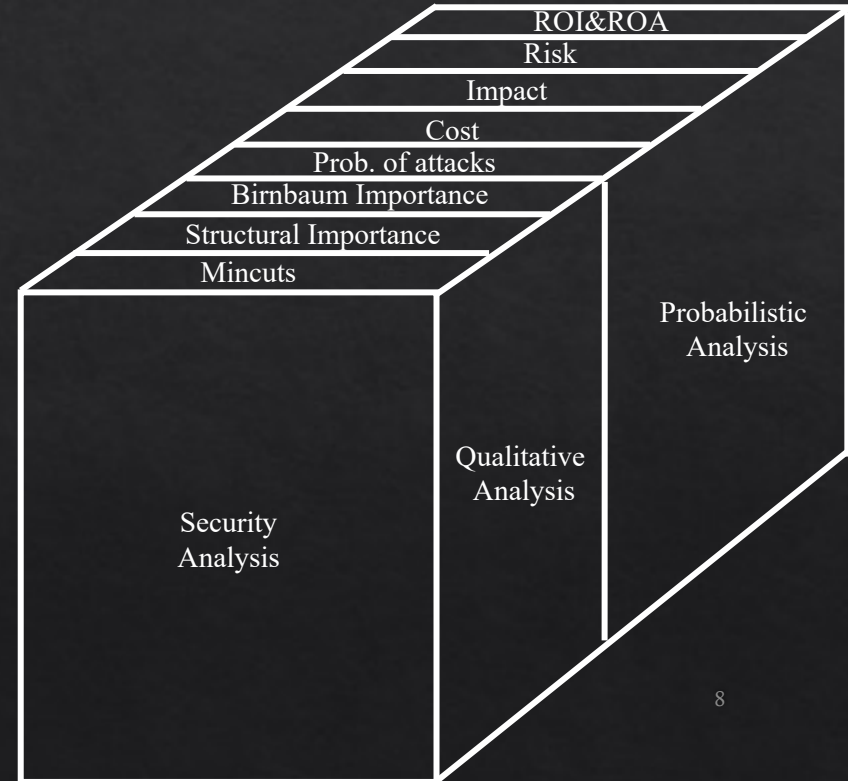
- ◇ What do we want to measure?



Security Metrics



◇ What can we measure?



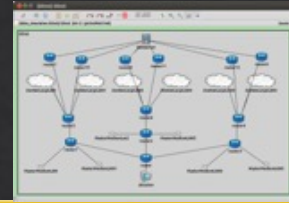
Security Metrics



◇ Other way to categorise security metrics:



Security Models



Security Models

Tree based

Attack Trees

Defense Trees

...

Attack Countermeasure Trees (ACT)

Graph based

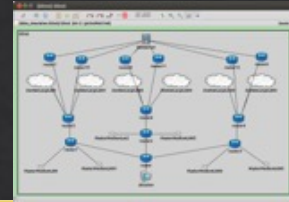
Attack Graphs

...

Hybrid

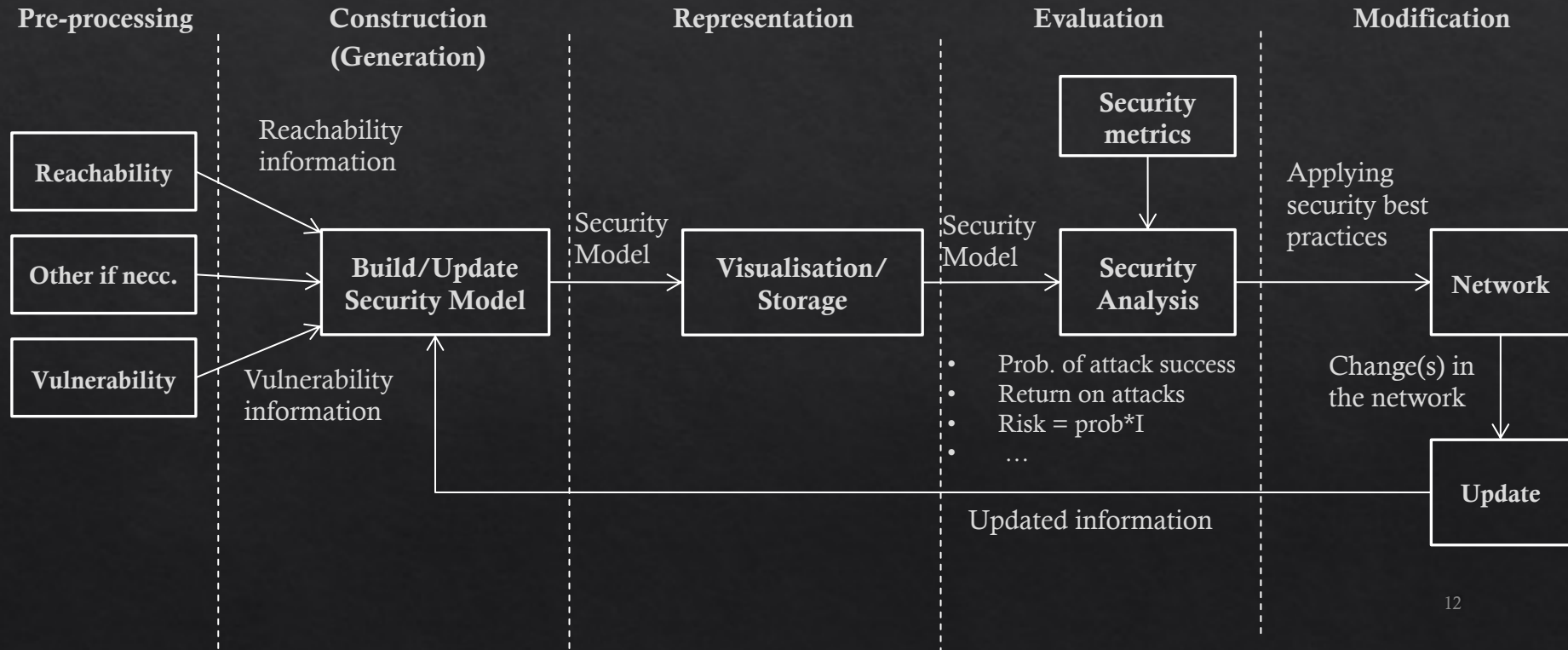
Hierarchical Attack Representation models (HARMs)

Security Models



- ◇ Security models can...
 - ◇ Capture and analyse attack scenarios
 - ◇ Perform automated security analysis
 - ◇ Compute optimal countermeasures
 - ◇ Use various security metrics

Security Model Lifecycle



Attack Trees

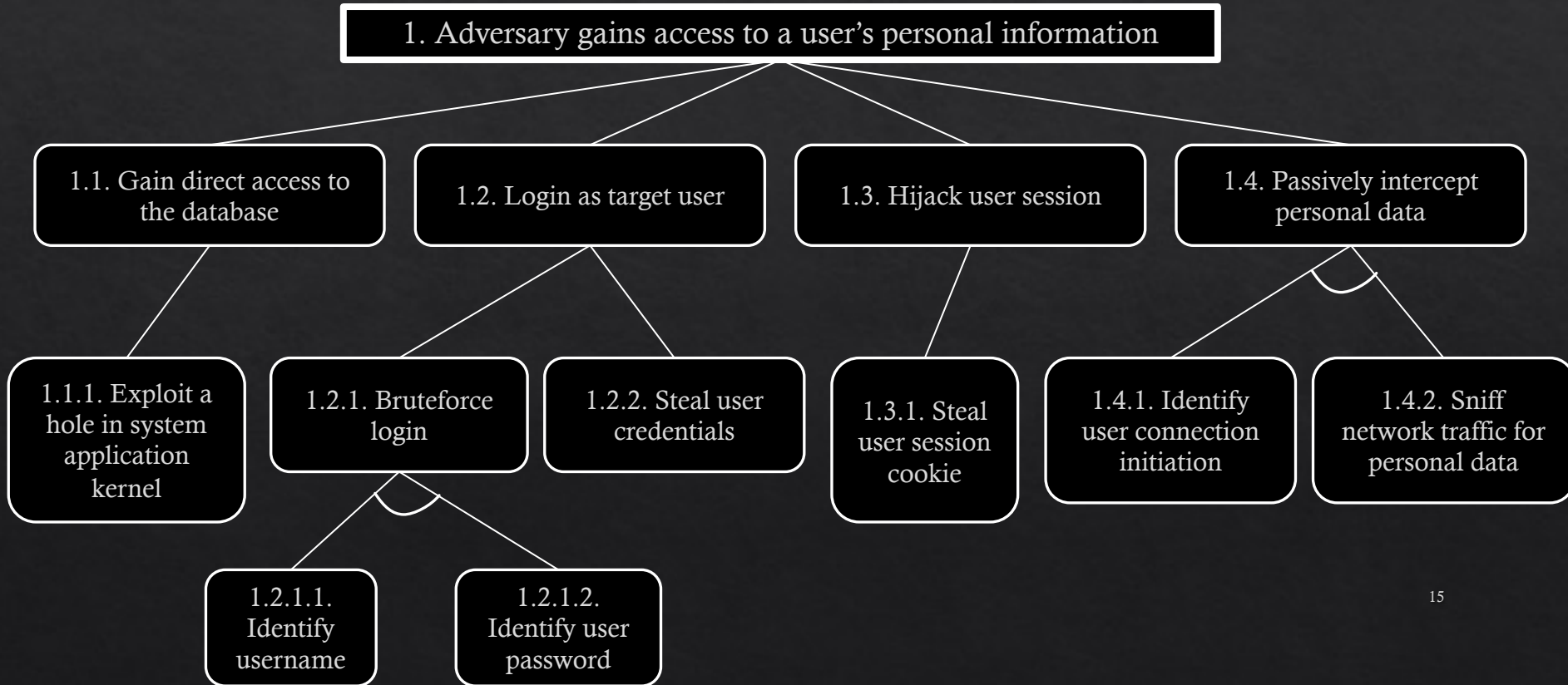
- ◇ Let us take a look at an Attack Tree (AT)
- ◇ ATs can
 - ◇ describe security of systems and subsystems
 - ◇ Specify and decompose attack goals and steps to achieve it
 - ◇ Evaluate the severity of different vulnerabilities in the system
 - ◇ Helps making decision to improve security

Attack Trees

◇ Structure

- ◇ Represent the attacks and countermeasures as a tree structure
- ◇ Root node is the goal of the attack
- ◇ Leaf nodes represents (atomic) attacks
- ◇ Uses logical gates to connect different attack events
 - ◇ E.g., uses of AND or OR gates
 - ◇ Attacker needs a swipe card AND pin number
 - ◇ Attacker needs to pick the lock OR break a window

Attack Trees



Attack Trees

1. Adversary gains access to a user's personal information

OR 1.1 Gain direct access to the database

1.1.1 Exploit a hole in system application or kernel

1.2 Log in as target user

OR 1.2.1 Brute-force login

AND 1.2.1.1 Identify username

1.2.1.2 Identify user password

1.2.2 Steal user credentials

1.3 Hijack user session

1.3.1 Steal user session cookie

1.4 Passively intercept personal data

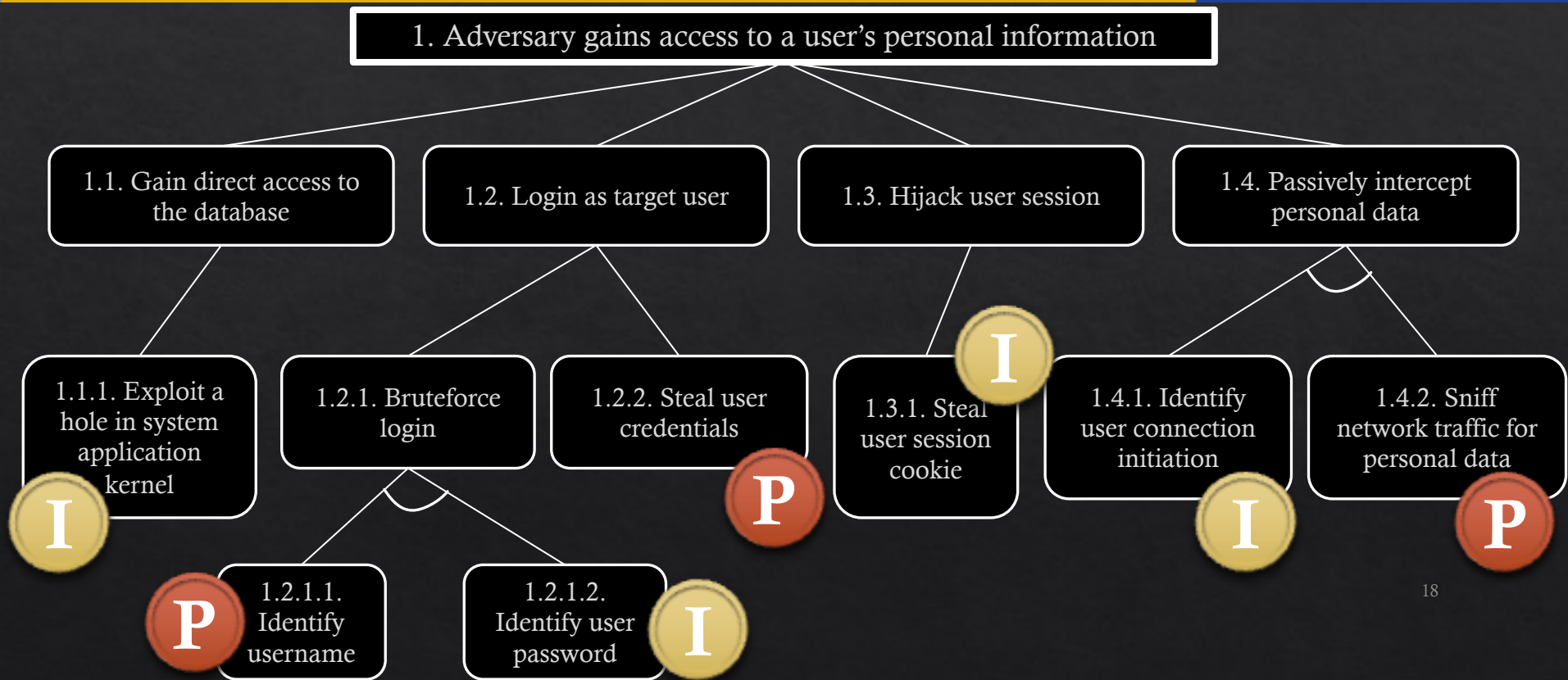
AND 1.4.1 Identify user connection initiation

1.4.2 Sniff network traffic for personal data

Attack Trees

- ◆ Leaf nodes can be assigned values to evaluate ATs
 - ◆ Boolean
 - ◆ Continuous
 - ◆ Other
 - ◆ Combined

Attack Trees



Attack Trees

OR: min
AND: sum

1. Adversary gains access to a user's personal information

1.1. Gain direct access to the database

1.2. Login as target user

1.3. Hijack user session

1.4. Passively intercept personal data

1.1.1. Exploit a hole in system application kernel

\$200

1.2.1. Bruteforce login

1.2.2. Steal user credentials

\$400

1.3.1. Steal user session cookie

\$50

1.4.1. Identify user connection initiation

\$20

1.4.2. Sniff network traffic for personal data

\$40

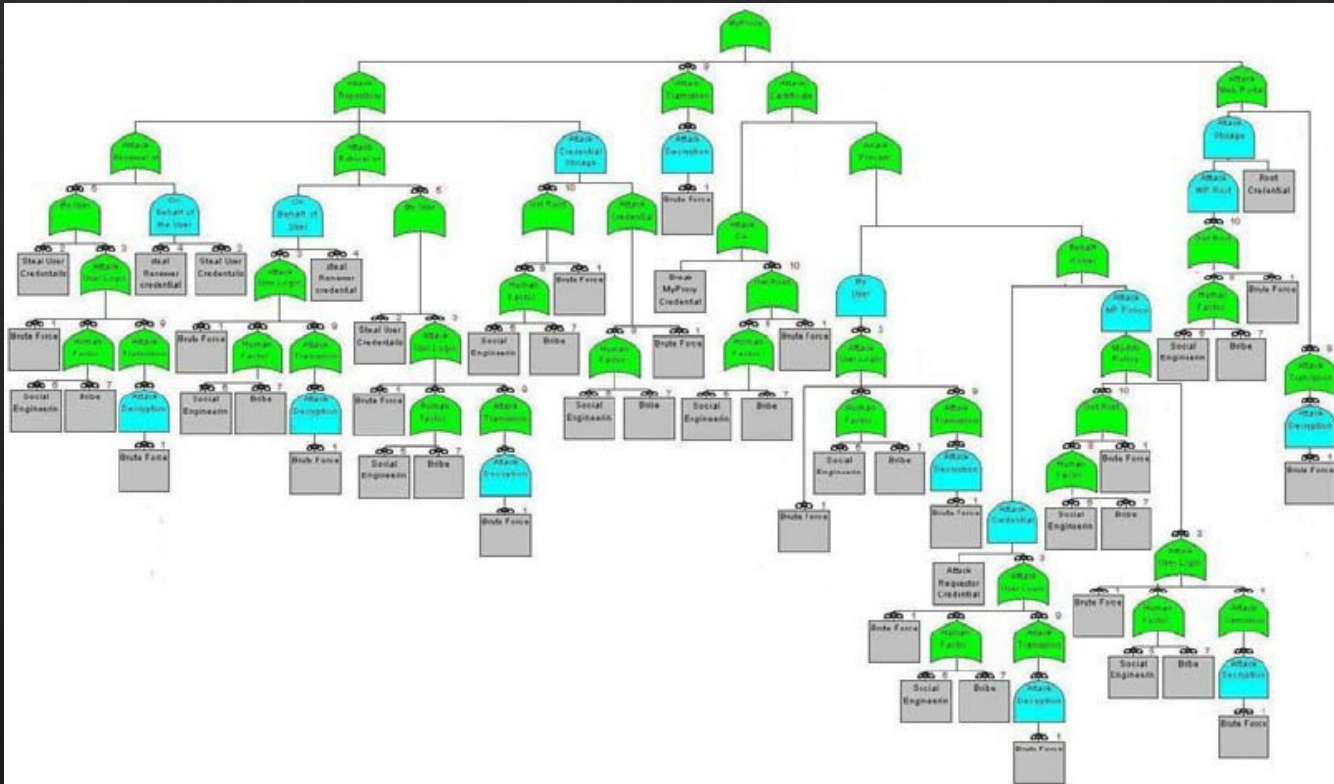
1.2.1.1. Identify username

\$5

1.2.1.2. Identify user password

\$50

Attack Trees



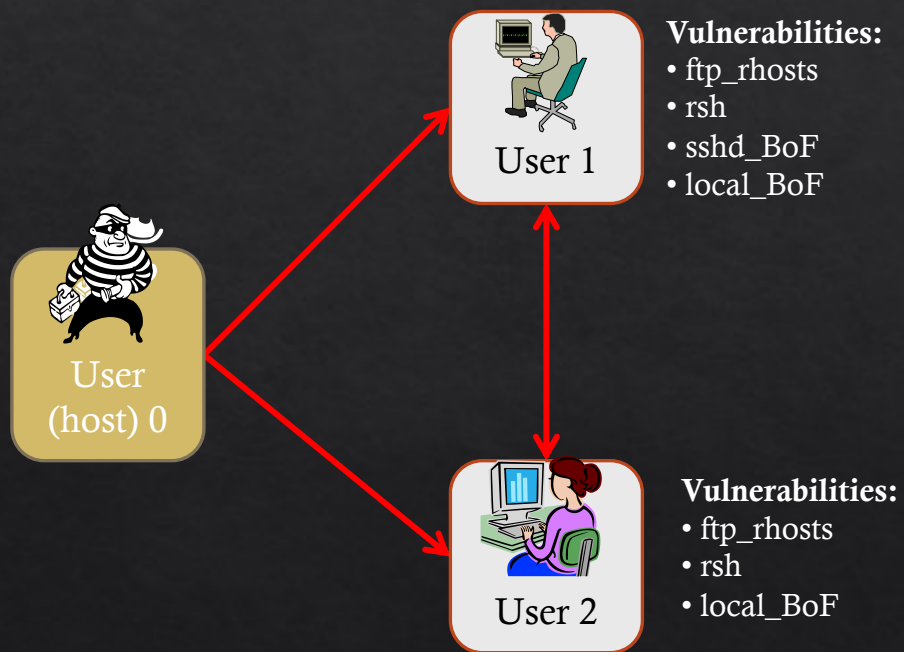
Attack Trees

- ◆ Computations become more complex when using different types of gates for joining leaf nodes
 - ◆ Sequential AND, k-out-of-n gates etc...
- ◆ Many variants of the ATs
 - ◆ Protection Trees, Defense Trees, Attack Countermeasure Trees etc...
- ◆ There are various tools to generate ATs
 - ◆ SeaMonster
 - ◆ AttackTree+ (commercial)
 - ◆ SecuITree (commercial)
 - ◆ ATSyRa
 - ◆ Attack Navigator

Attack Graphs

- ◇ Similar technique to ATs
- ◇ Unlike ATs, AGs may have cyclic dependencies or merged states
 - ◇ State transition information
 - ◇ Order of events
 - ◇ Etc.

Attack Graphs



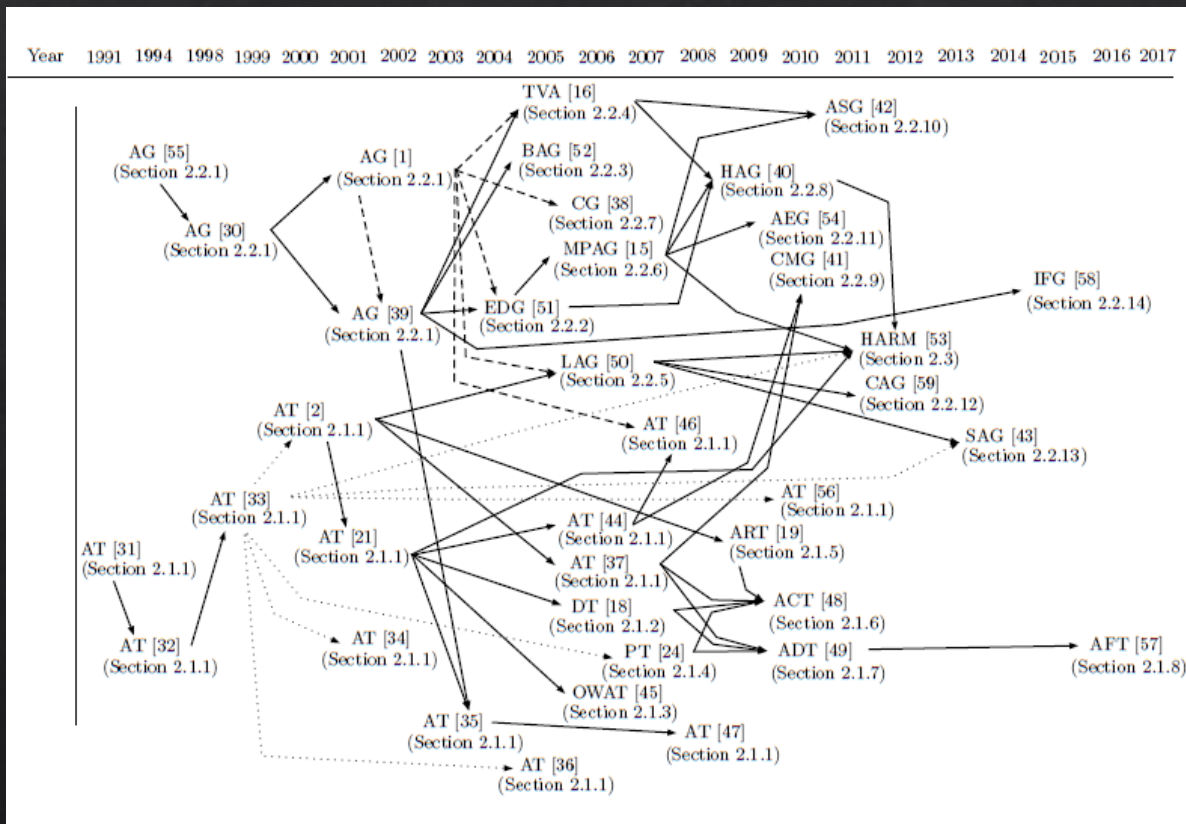
Attack Graphs

- ◇ Many variants of the AGs
 - ◇ Logical AGs, Bayesian AGs, Multiple prerequisite AGs, etc...
- ◇ There are tools available to generate AGs
 - ◇ NuSMV
 - ◇ RedSeal (commercial)
 - ◇ Skybox (commercial)
 - ◇ Cauldron (commercial)
 - ◇ CyGraph

What type do you use?

- ◇ Depends on various factors
 - ◇ What metrics can I use?
 - ◇ How efficient is the security assessment?
 - ◇ What tools are available?
 - ◇ What type of attacks can it model?
 - ◇ Which systems can I use the model?
 - ◇ Etc...

Evolution of Graphical Security Models (GSMs)



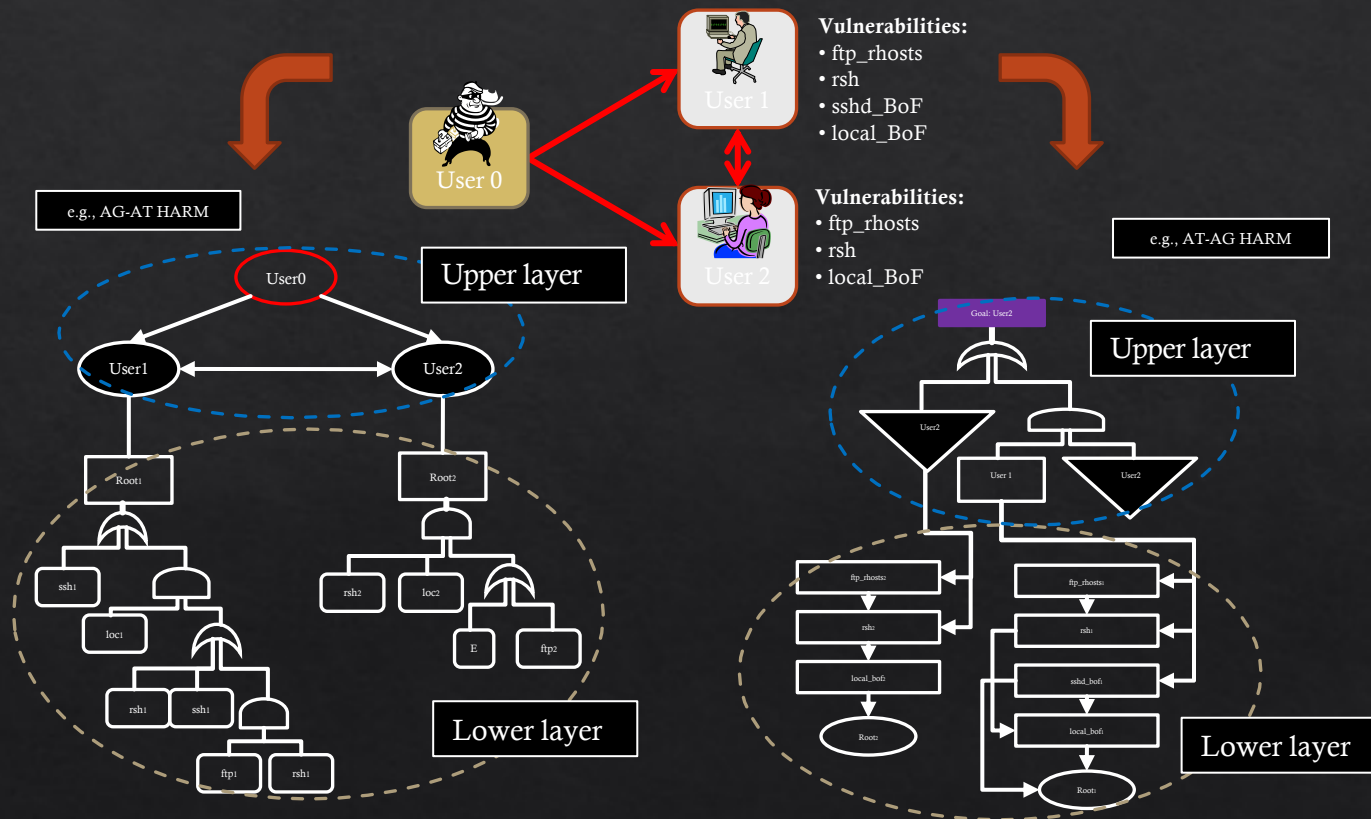
Limitations

- ◇ Scalability issues
 - ◇ The generation of full attack models and evaluation of all possible attack scenarios exhibit a **state-space explosion**
- ◇ Dynamic adjustment (Adaptability) issues
 - ◇ A change in the network system **causes updates** in the security model
- ◇ Automating security decisions and countermeasure selections issues
 - ◇ Requires intelligent **security decision making** and **real-time adaptation and deployment** of security solutions.

Limitations

- ◇ To address the scalability issues
 - ◇ Adopt new modelling techniques
 - ◇ E.g., using hierarchy, etc...
 - ◇ Implement efficient generation and evaluation algorithms
 - ◇ E.g., heuristic, dynamic programming solutions, etc...
 - ◇ Anything else?
 - ◇ E.g., subgraph evaluation, parallel computing

Approach 1: Hierarchy



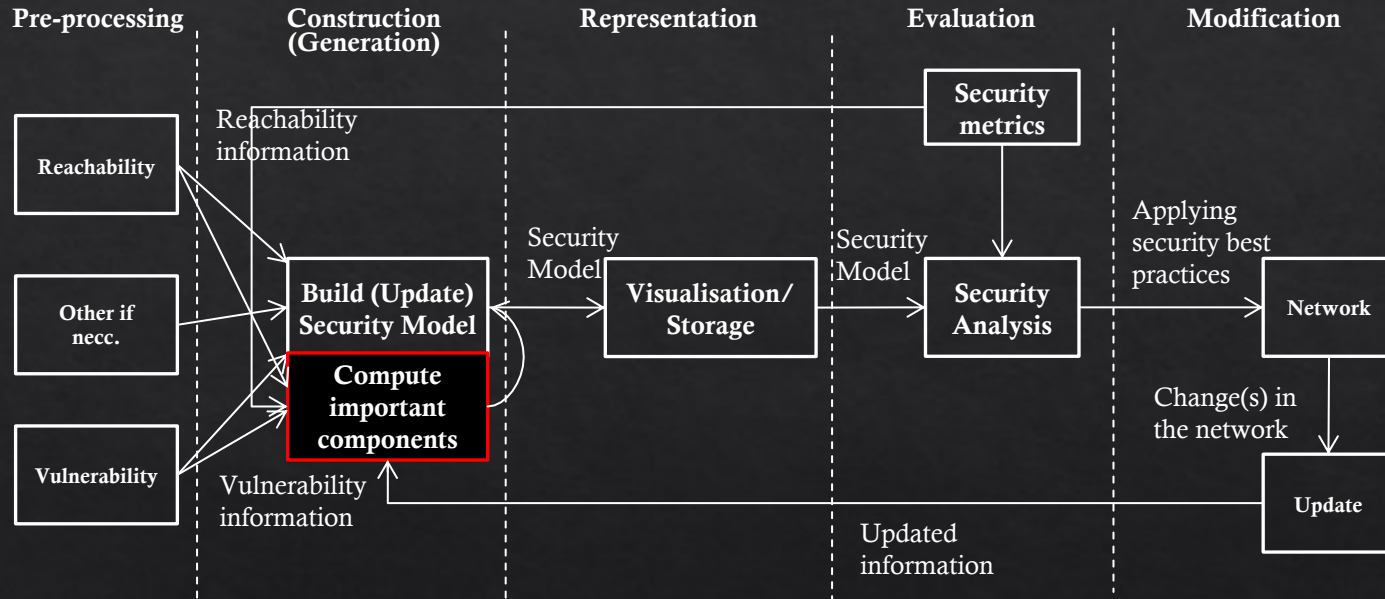
Approach 2: Importance Measures

- ◇ When analysing network security, there are only a **subset** of network components that have a critical role in an event of an attack.
- ◇ **All** network components are considered when the GSMs are constructed.
- ◇ To **improve** the performance of both construction and evaluation phases of GSMs, we consider to use only important hosts and vulnerabilities.

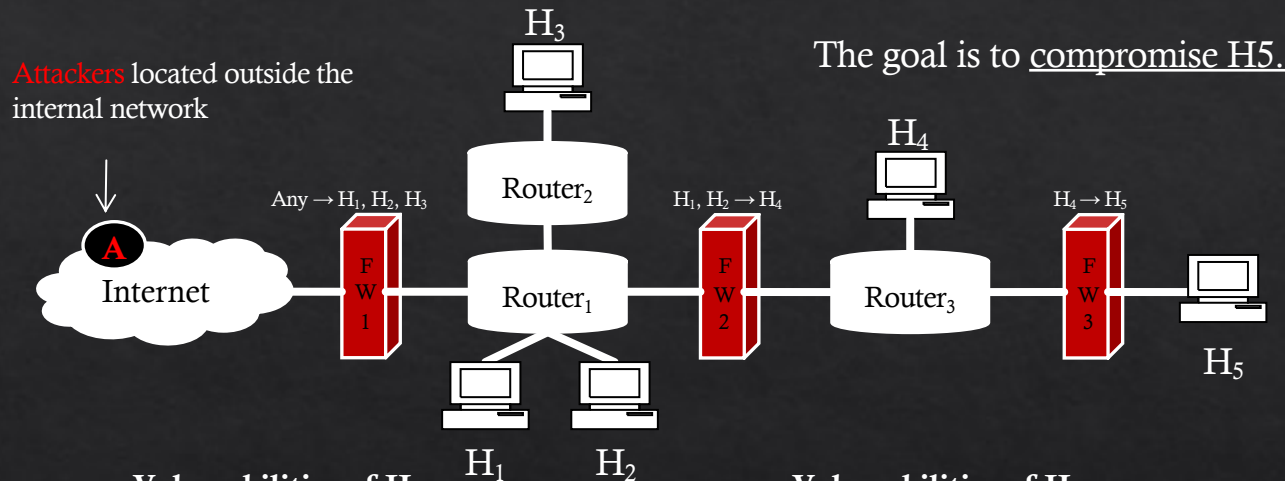
Use Importance Measures



Recap – Lifecycle of Graphical Security Models



An Example Networked System



Vulnerabilities of H_1

ID	CVE ID	CVSS BS	Impact	Exploitability	CI	Access Level	Authentication
v ₁	CVE-2005-1794	6.4	4.9	10.0	P	None	None
v ₂	CVE-2011-0661	10.0	10.0	10.0	C	None	None
v ₃	CVE-2010-0231	10.0	10.0	10.0	C	None	None
v ₄	CVE-2011-2552	7.8	6.9	10.0	N	None	None
v ₅	CVE-1999-0520	6.4	4.9	10.0	P	None	None
v ₆	CVE-2010-2729	9.3	10.0	8.6	C	None	None
v ₇	CVE-1999-0505	7.2	10.0	3.9	C	Admin	None
v ₈	CVE-2002-1117	5.0	2.9	10.0	P	None	None
v ₉	CVE-2003-0386	4.3	2.9	8.6	P	None	None
v ₁₀	CVE-2010-0025	5.0	2.9	10.0	P	None	None
v ₁₁	CVE-1999-0497	0.0	0.0	10.0	N	None	None

Vulnerabilities of H_5

ID	CVE ID	CVSS BS	Impact	Exploitability	CI	Access Level	Authentication
v ₁₂	CVE-2011-1789	5.0	2.9	10.0	N	None	None
v ₁₃	CVE-2011-1786	5.0	2.9	10.0	N	None	None
v ₁₄	CVE-2011-1785	7.8	6.9	10.0	N	None	None
v ₁₅	CVE-2011-0355	7.8	6.9	10.0	N	None	None
v ₁₆	CVE-2010-4573	9.3	10.0	8.6	C	None	None
v ₁₇	CVE-2010-3609	5.0	2.9	10.0	N	None	None
v ₁₈	CVE-2010-1142	8.5	10.0	6.8	C	None	Single System
v ₁₉	CVE-2010-1141	8.5	10.0	6.8	C	None	Single System
v ₂₀	CVE-2009-3733	5.0	2.9	10.0	P	None	None
v ₂₁	CVE-2008-4281	9.3	10.0	8.6	C	None	None
v ₂₂	CVE-2008-2097	9.0	10.0	8.0	C	Admin	Single System

using vulnerability scanners such as **NESSUS**

Ranking hosts

◇ Ranking Hosts w.r.t NCMs

	Degree	Closeness	Betweenness	Rank Sum	Final Rank
H_1	3/4	4/5	8/12	4	2
H_2	3/4	4/5	8/12	4	2
H_3	2/4	4/7	4/12	12	4
H_4	3/4	4/5	10/12	3	1
H_5	1/4	4/12	4/12	14	5

We combine all NCMs to formulate the final rank

-For our example, each rank acted as a score to give the final rank
(i.e., scores are used to re-rank nodes)

-Rankings from each NCM are used as the importance score

Ranking vulnerabilities on hosts

◇ Ranking Vulnerabilities

Vulnerabilities of $H_1 - H_4$

	v_1	v_2	v_3	v_4	v_5	v_6	v_7	v_8	v_9	v_{10}	v_{11}
CVSS BS	6.4	10.0	10.0	7.8	6.4	9.3	7.2	5.0	4.3	5.0	0.0
Rank	6	1	1	4	6	3	5	8	10	8	11

Vulnerabilities of H_5

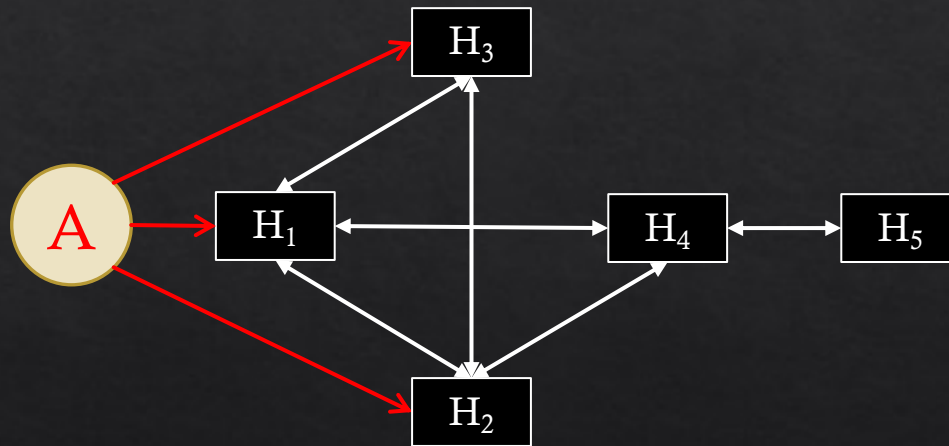
	v_{12}	v_{13}	v_{14}	v_{15}	v_{16}	v_{17}	v_{18}	v_{19}	v_{20}	v_{21}	v_{22}
CVSS BS	5.0	5.0	7.8	7.8	9.3	5.0	8.5	8.5	5.0	9.3	9.0
Rank	8	8	6	6	1	8	4	4	8	1	3

Vulnerabilities are ranked based on their CVSS BSs

Important vulnerabilities are selected based on the threshold value
(e.g., higher than the average CVSS BS)

Full HARM

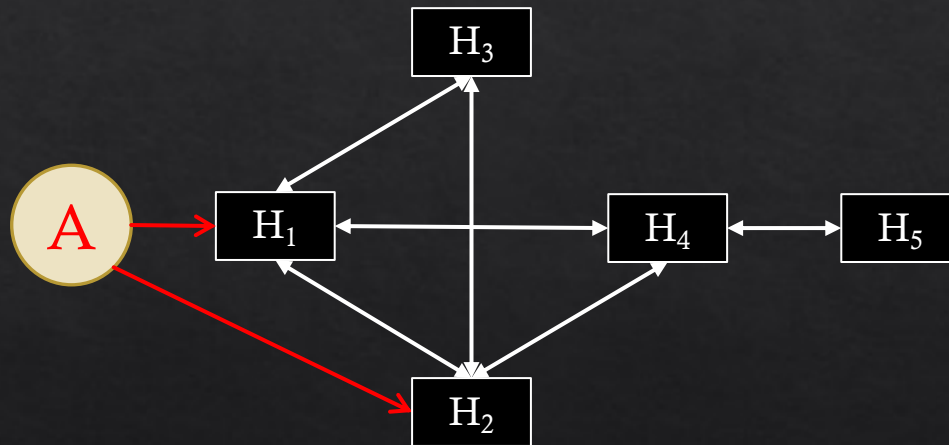
◇ The upper layer



Upper layer (AG)

Simplified HARM

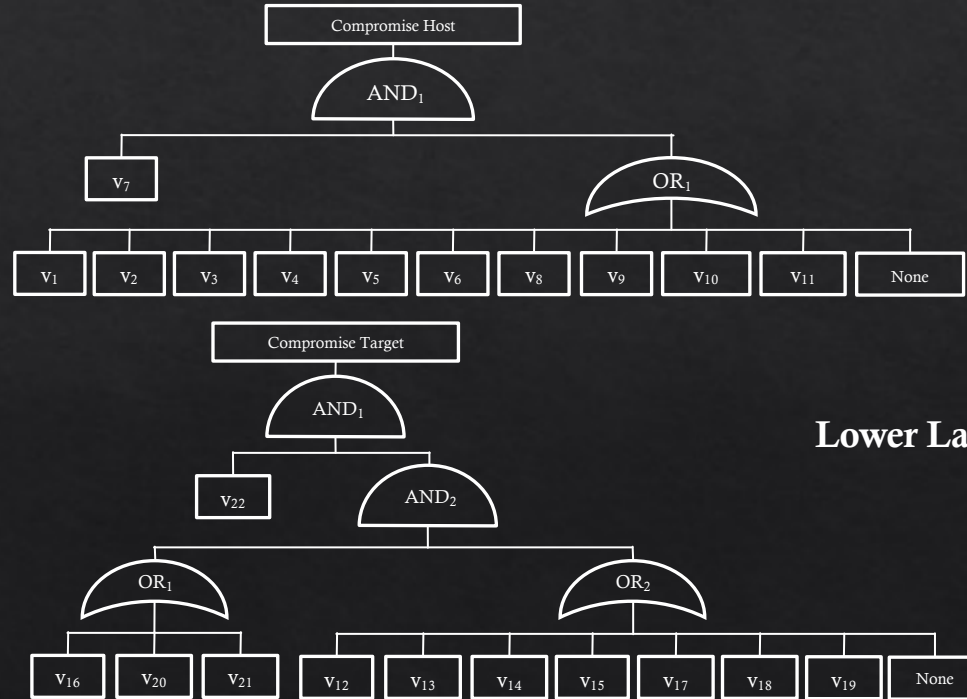
- ◇ The upper layer: Using only important **hosts**



Upper layer (AG)
Using 3 hosts

Full HARM

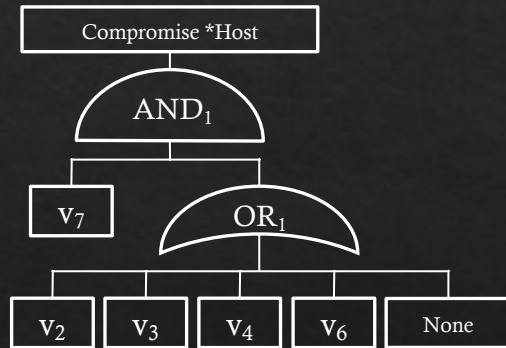
◇ The lower layer



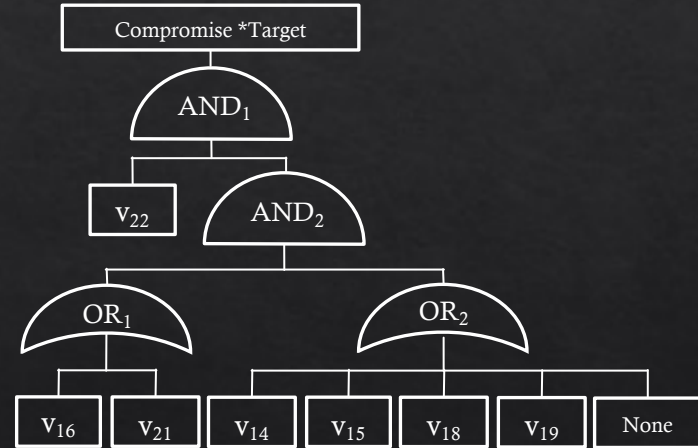
Lower Layer (AT)

Simplified HARM

- ◇ The lower layer: using Important **vulnerabilities**



Using 5 vulnerabilities

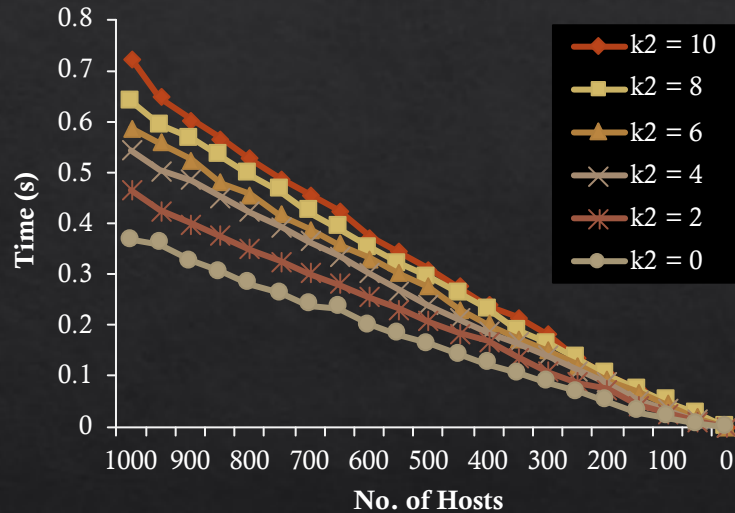


Using 7 vulnerabilities

Lower Layer (AT)

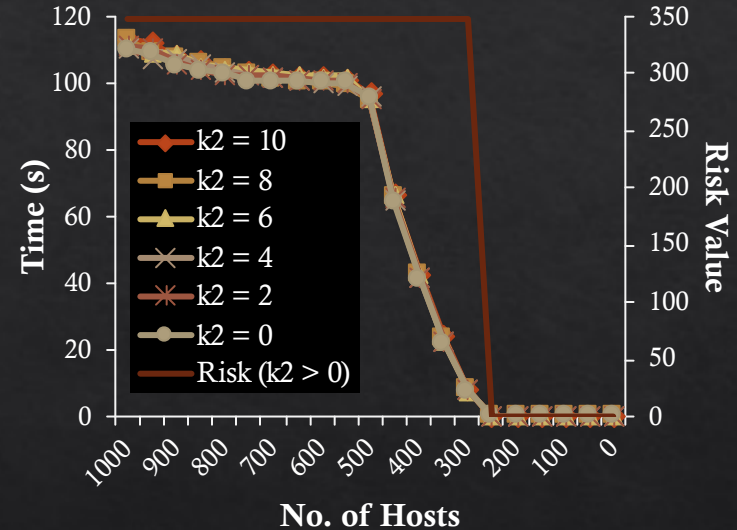
Simulation results

◇ Host based security analysis



Construction

(with k_2 number of vulnerabilities)



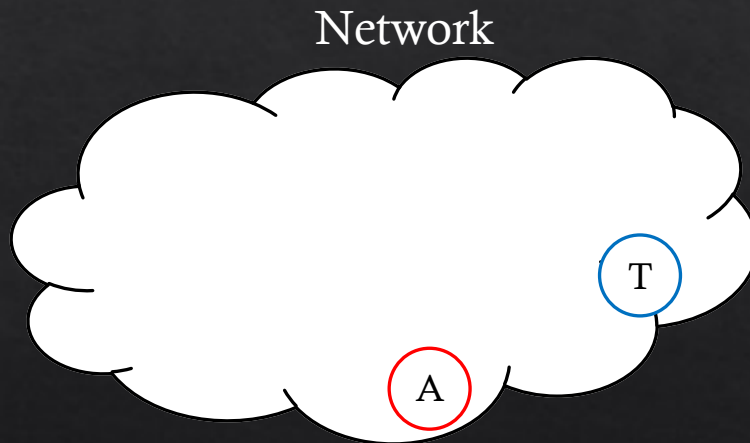
Evaluation

(with k_2 number of vulnerabilities)

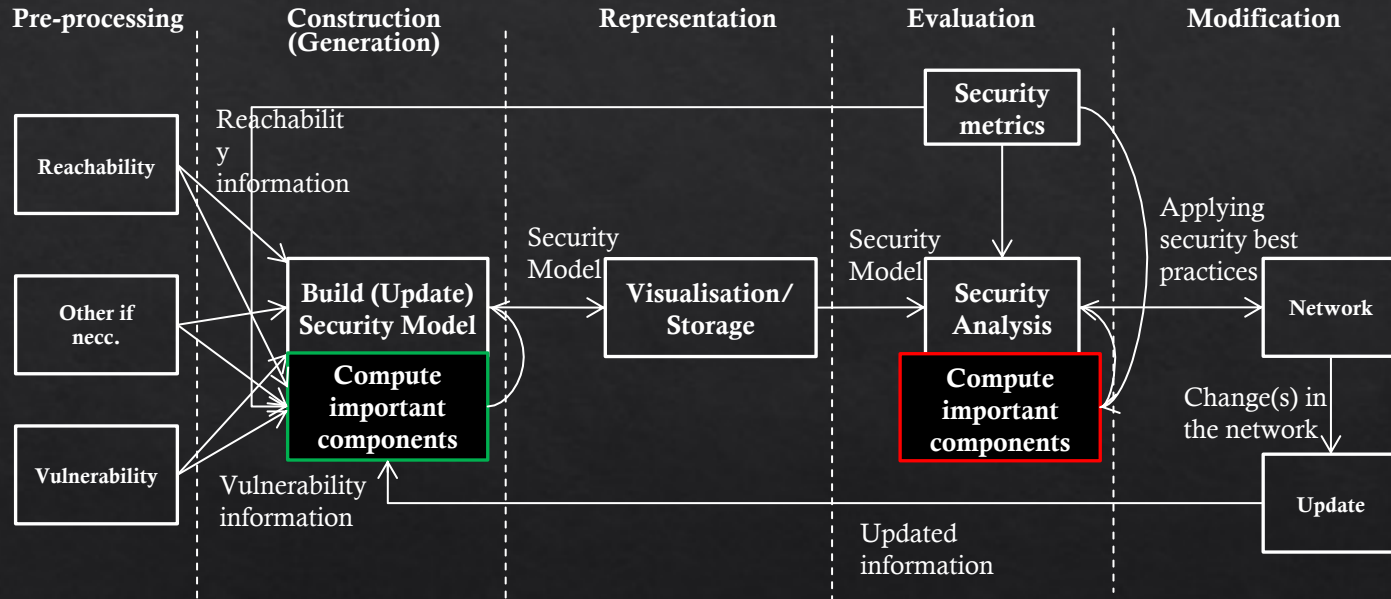
The construction time linearly improves as the number of important hosts modeled reduce. For evaluation, there is a steady improvement until the host number reaches 500. From then, it rapidly improves the performance.

Network coverage

- ◆ Consider an attack scenario that covers only a subset of the network (e.g., an attacker located inside the network).

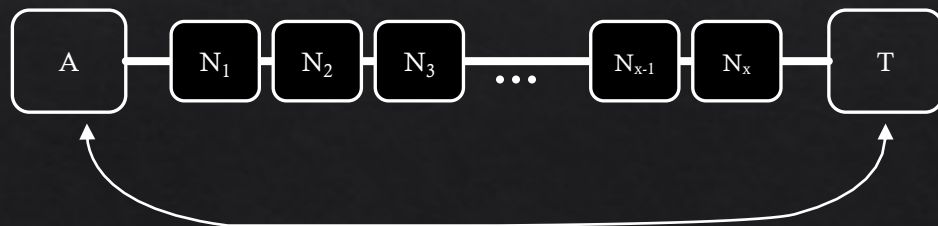


Recap – Lifecycle of Graphical Security Models



Attacker to Victim Centrality (AVC)

- Upper layer NCMs do **not** consider the place of the attacker and the target (victim).
- We define a location-based (Attacker to Victim) centrality (AVC) measurement based on **distance** measurements.



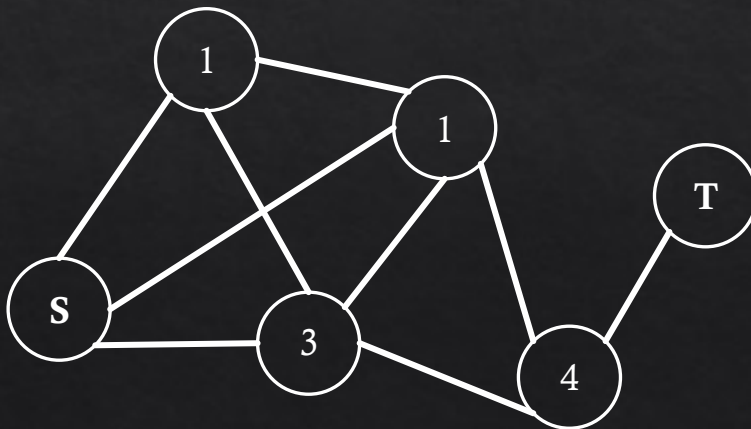
Measure distance between A and T

Attacker to Victim Centrality (AVC) (cont.)

- ◇ Ranking important hosts using location based centrality

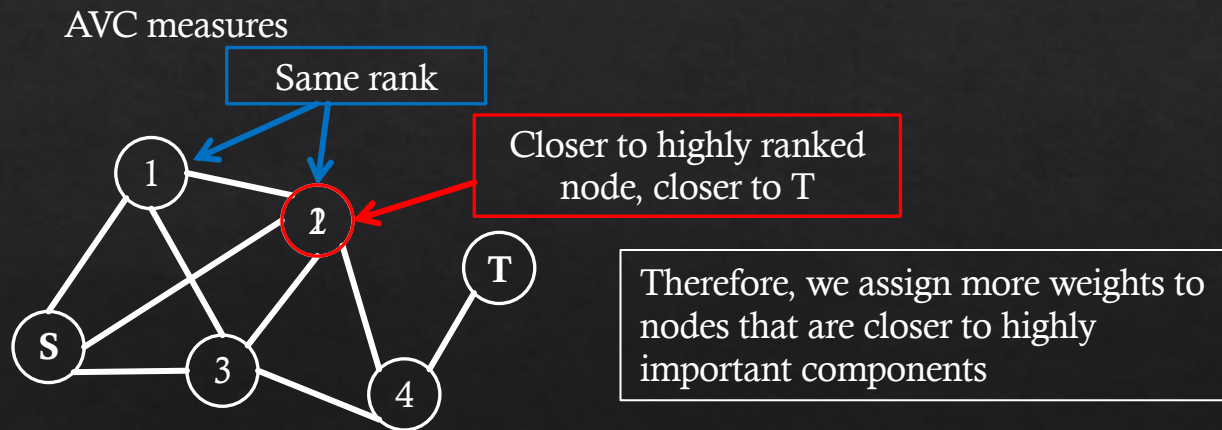
- ◇ Attacker to Victim Centrality (AVC)

Importance measure based on the node **location**



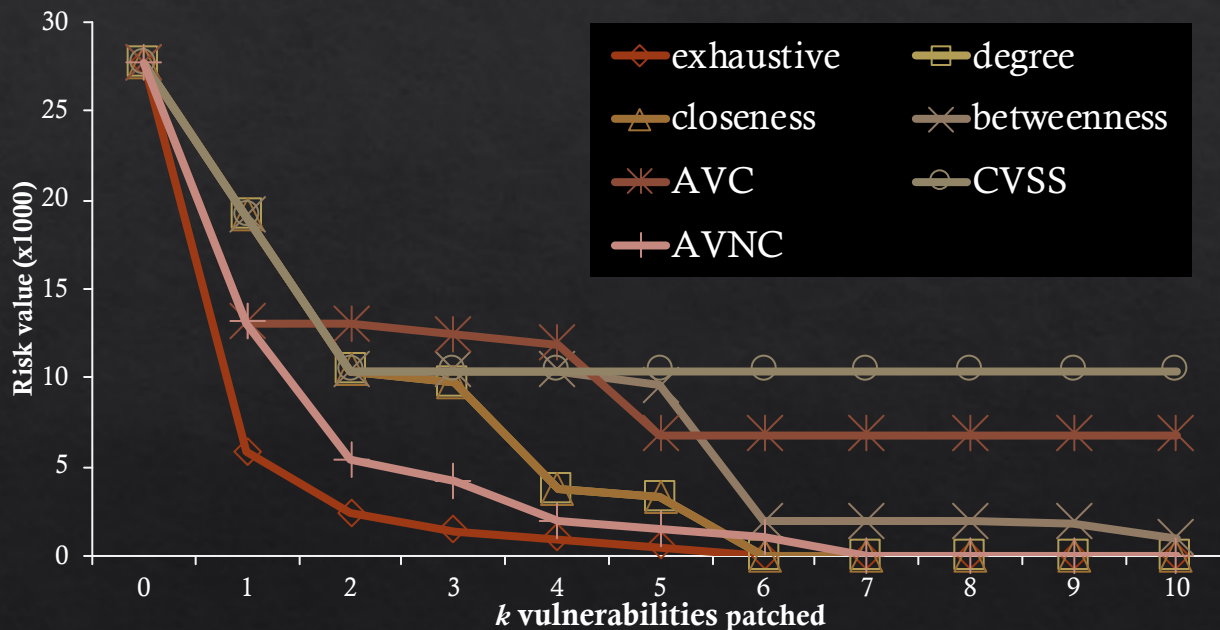
Attacker to Victim **Neighbour** Centrality (AVNC)

- ◇ If there are components with the **same** ranking, then the AVC may not identify important components correct.



Security Analysis via Simulation

◇ Results – multiple subnets, **internal** attacker



The location based centrality measure AVNC performs most closely to the exhaustive search.

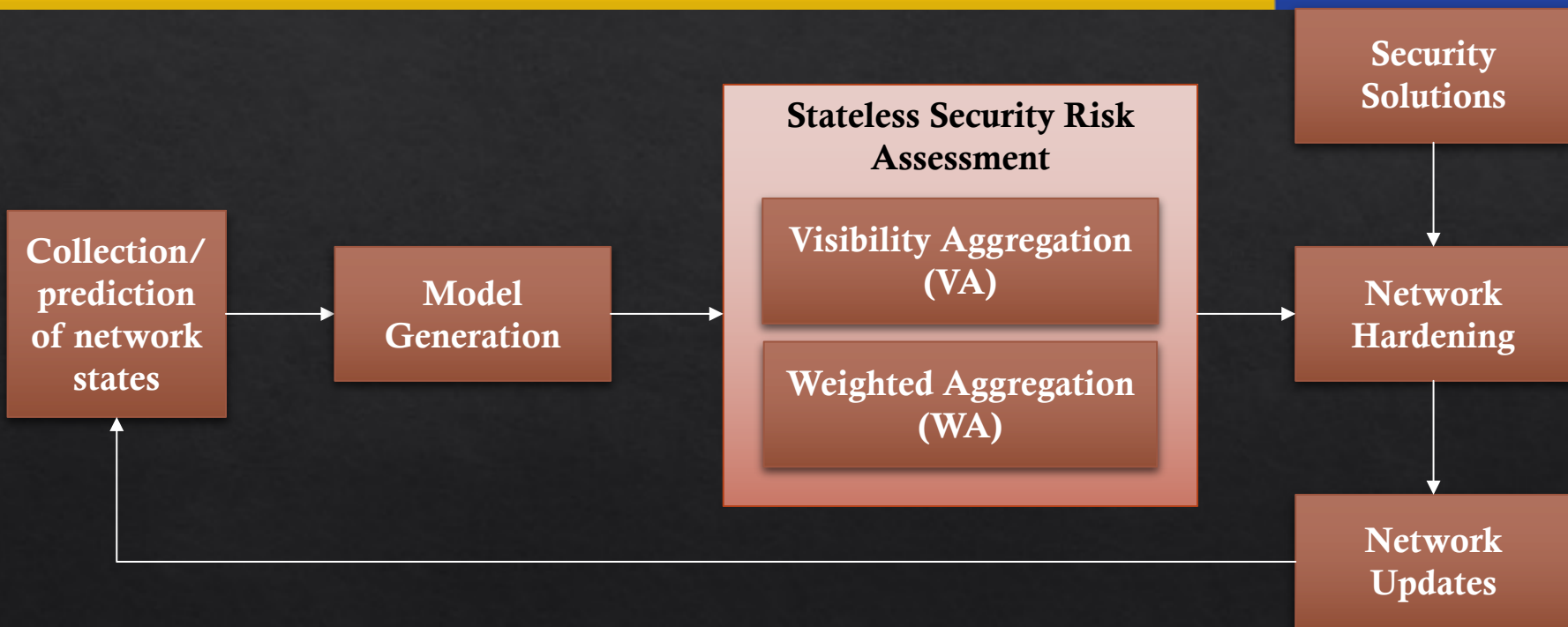
Limitations

- ◇ To address the dynamic adjustment issues
 - ◇ Capture dynamic changes using the model
 - ◇ E.g., use of temporal graphs
 - ◇ Real-time change detection mechanisms
 - ◇ E.g., real-time IDS, system logging etc...
 - ◇ Develop dynamic security metrics for evaluations
 - ◇ E.g., identifying persistent vulnerability etc...
- ◇ Anything else?

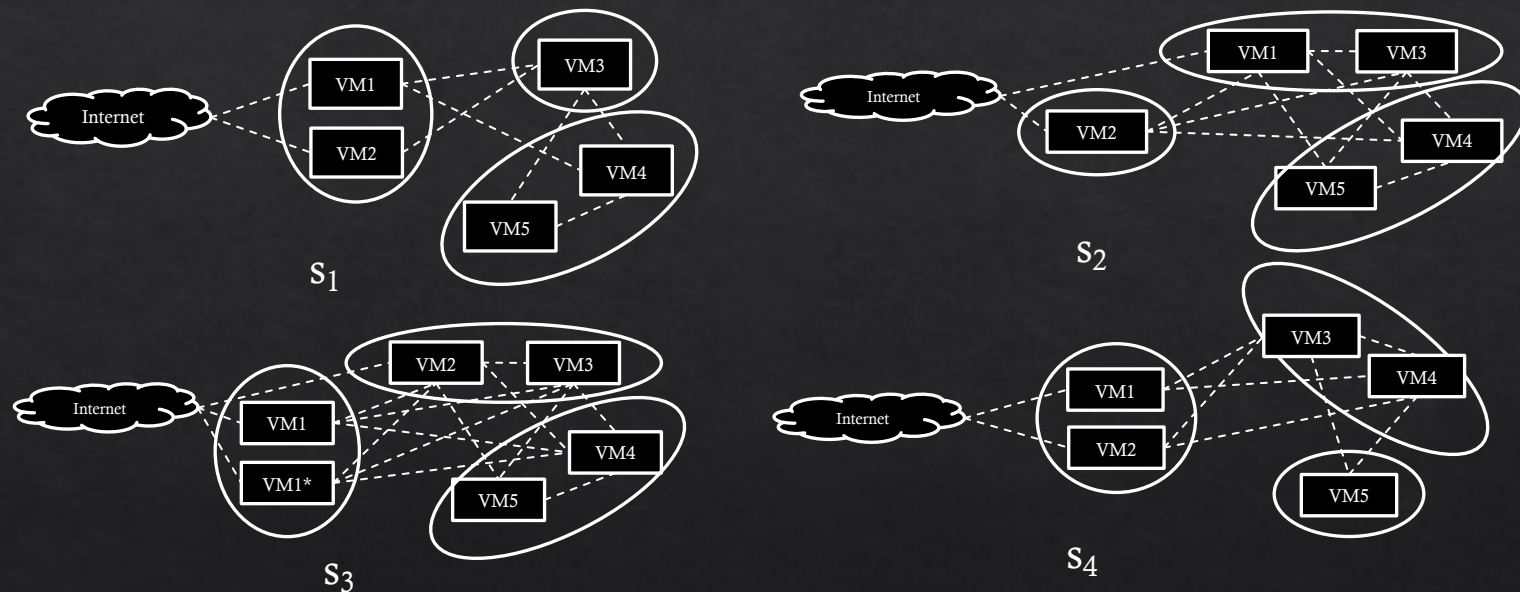
Proposed approach: stateless security risk assessment

- ◇ We propose “*stateless*” security risk assessment to capture the overall security posture of dynamic networks.
 - ◇ Since dynamic networks create different network states over time, we collect all the network state information over time.
- ◇ A *network state* refers to a specific network configuration and its component observed at the time.
- ◇ To provide the security overview for the whole period, we aggregate the observed network states using two approaches.
 - ◇ Visibility Aggregation (VA)
 - ◇ Weighted Aggregation (WA)

Proposed approach: stateless security risk assessment (cont.)



Example dynamic network



For example, we observe the following states

Time t_i	1	2	3	4	5	6	7	8	9	10
State s_i	s1	s1	s3	s1	s2	s2	s2	s1	s4	s4

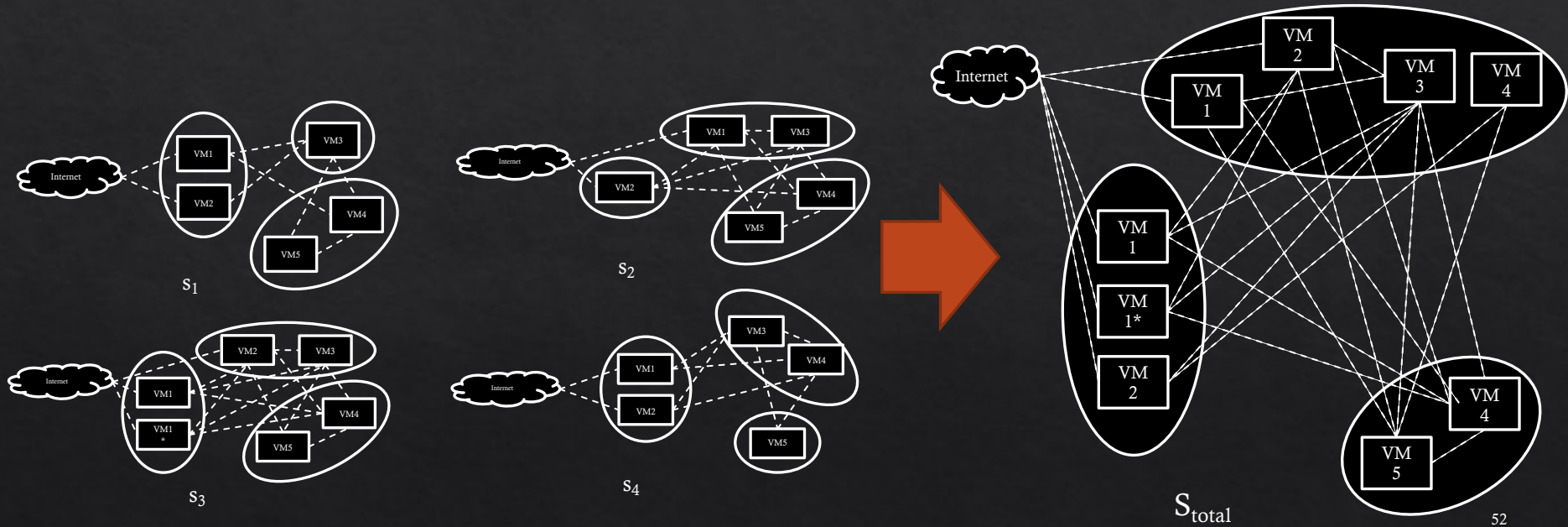
Visibility Aggregation (VA)

- ◇ All the observed network states are aggregated maintaining all the enabled configurations
 - ◇ e.g., host-to-host connections, running applications
- ◇ This collects all the potential security risk of the dynamic network
- ◇ Advantages
 - ◇ All network state information is represented
 - ◇ This risk value will not change unless the network/threat changes
- ◇ Disadvantage
 - ◇ Does not reflect the exposure of different states

```
S: a set of all network states;  
for  $s \in S$  do  
  | if components of  $s_i$  not in  $s_{init}$  then  
  |   |  $s_{init} = s_{init} \cup s_i$ ;  
  |   end  
end  
Assess the security of  $s_{init}$ ;  
Algorithm 1: VA approach
```

Visibility Aggregation (VA) (cont.)

◇ We aggregate all the observed states



Perform security risk analysis of S_{total} .

Weighted Aggregation (WA)

- ◇ The weight factor is assigned to each observed network state based on the duration of exposure.
- ◇ Takes into account the exposure factor of each network state
- ◇ Advantages
 - ◇ All network state information is represented
 - ◇ Incorporate the exposure of different network states
- ◇ Disadvantage
 - ◇ Risk value may fluctuate based on the network behavior
 - ◇ e.g., exposure of network states change due to changing user behaviors

```
S: a set of all network states;  
ti: a time duration of si;  
T, the total duration of S;  
minit: a security metric to be computed;  
for s ∈ S do  
    | mi ← security assessment of si;  
    | minit = minit + (mi ×  $\frac{t_i}{T}$ );  
end  
return minit;
```

Algorithm 2: WA approach

Weighted Aggregation (cont.)

Weight = observed no. of states / total No. of states

◇ For the example dynamic network

	s_1	s_2	s_3	s_4	Total
Weight	0.4	0.3	0.1	0.2	1
Risk value*	100	130	80	50	-
Weighted risk value	40	39	8	10	97

Initial Experimental results

- ◇ We created a randomly generated network with a set number of hosts and edges between the hosts.
- ◇ Each host is assigned with an arbitrary number of vulnerabilities (1- 10) from the National Vulnerability Database (NVD)
- ◇ We implemented random **changes** in the generated network to make changes over time
 - ◇ Host addition/removal
 - ◇ Vulnerability addition/removal
 - ◇ Edge addition/removal
- ◇ We observed 8 network states for the evaluation

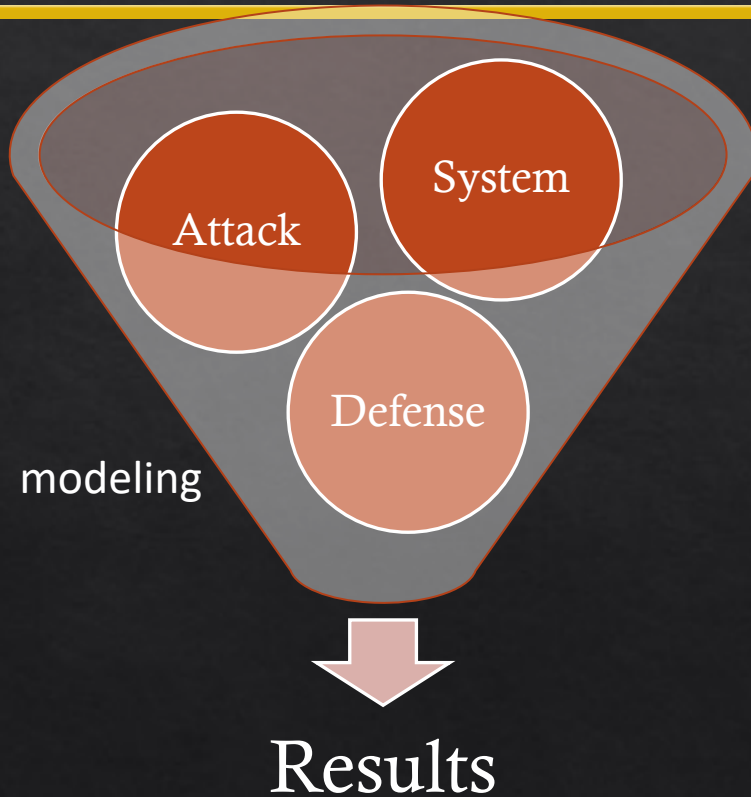
Initial Experimental results

Network States	Security Risk	WA	Vulnerability to patch
S_1	42.8	5.8	V_{10}
S_1	104.3	11.4	V_3
S_1	67.4	6.5	V_3
S_1	91.9	11.4	V_3
S_1	122.4	15.4	V_{11}
S_1	90.7	29.5	V_{11}
S_1	90.7	29.5	V_{11}
S_1	90.7	29.5	V_{11}
S_{init}	185.6	-	V_{11}
sum	-	139.0	-

Limitations

- ◇ To address the automation issues
 - ◇ Develop intelligent security analysis modules
 - ◇ E.g., use of AI, machine learning etc...
 - ◇ Pool of countermeasures for implementations
 - ◇ E.g., security awareness, easy security solution adoption methods etc...
 - ◇ Secure system architecture planning and implementation
 - ◇ E.g., security forecast, prediction, attacker profiling etc...
 - ◇ Anything else?

What is the Research Gap?



Our Approach

System

Hierarchical Attack Representation Model

Defense

Various MTD Techniques (more next week!)

Attack

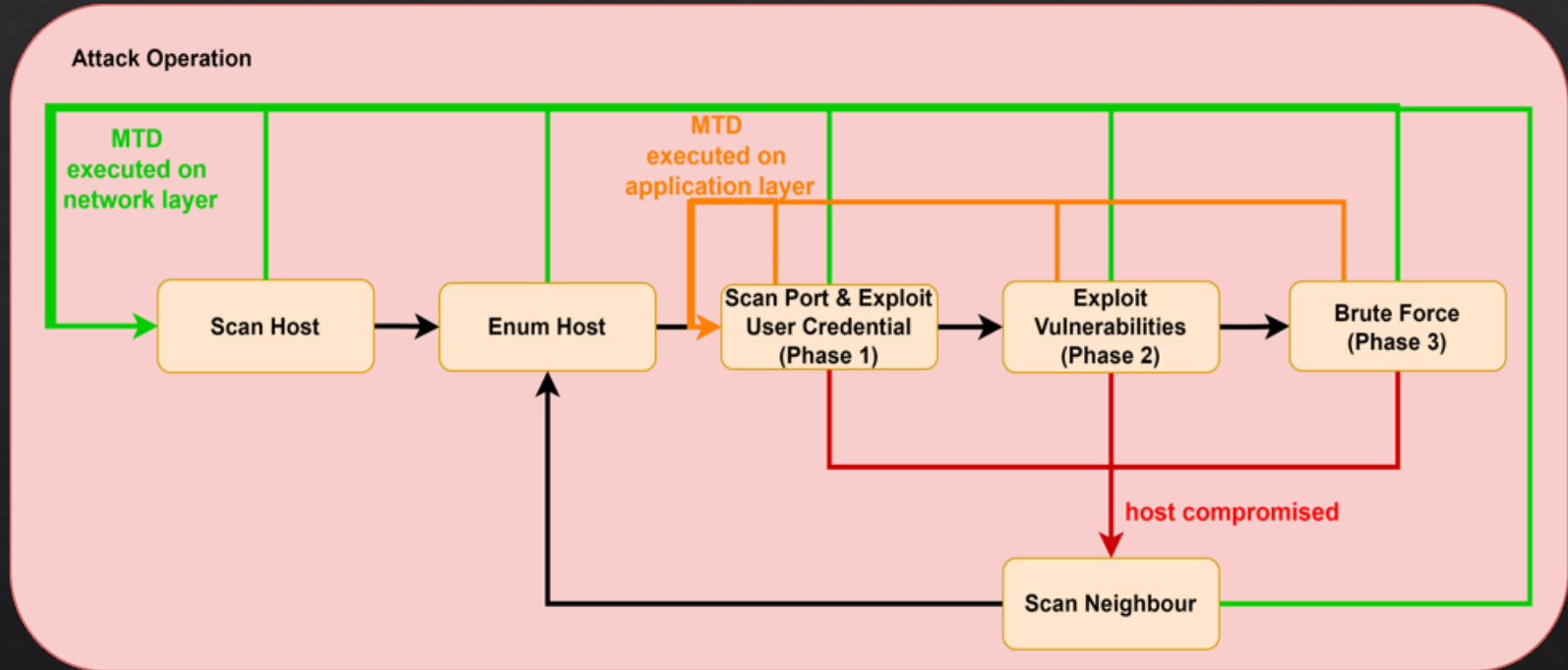
MITRE ATT&CK framework (i.e., attack profiling!)

What is MITRE ATT&CK Framework?

- ❖ "MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations."

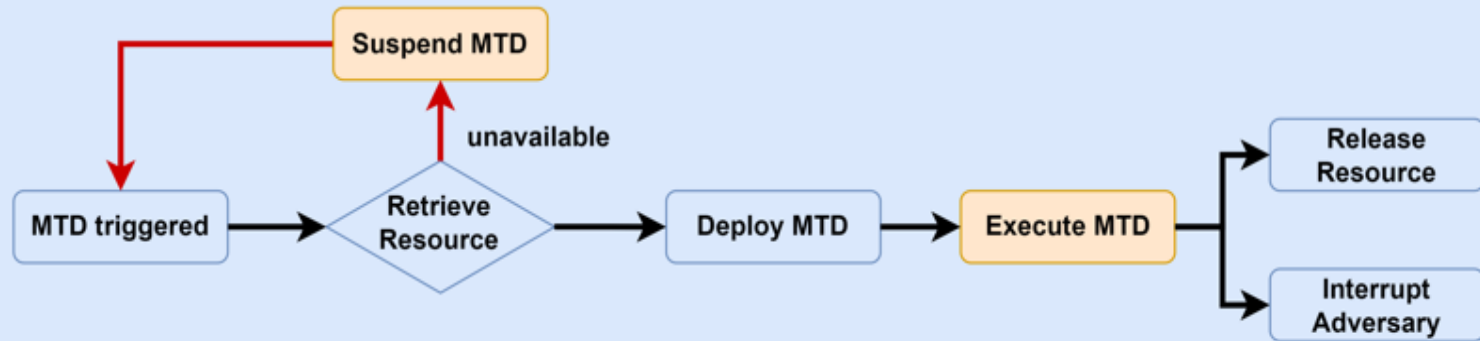
Reconnaissance 18 techniques	Resource Development 8 techniques	Initial Access 9 techniques	Execution 14 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 17 techniques
- Active Scanning (3) - Gather Victim Host Information (4) - Gather Victim Identity Information (3) - Gather Victim Network Information (4) - Gather Victim Org Information (4) - Phishing for Information (3) - Search Closed Sources (3) - Search Open Technical Databases (3) - Search Open Websites/Domains (3) - Search Victim-Owned Websites	- Acquire Access - Acquire Infrastructure (3) - Compromise Accounts (3) - Compromise Infrastructure (7) - Develop Capabilities (3) - Establish Accounts (3) - Obtain Capabilities (4) - Stage Capabilities (4)	- Drive-by Compromise - Exploit Public-Facing Application - External Remote Services - Hardware Additions - Phishing (3) - Replication Through Removable Media - Supply Chain Compromise (3) - Trusted Relationship - Valid Accounts (4)	- Cloud Administration Command - Command and Scripting Interpreter (3) - Container Administration Command - Deploy Container - Exploitation for Client Execution - Inter-Process Communication (3) - Native API - Scheduled Task/Job (3) - Serverless Execution - Shared Modules - Software Deployment Tools - System Services (3) - User Execution (3)	- Account Manipulation (3) - BITS Jobs - Boot or Logon Autostart Execution (14) - Boot or Logon Initialization Scripts (3) - Browser Extensions - Compromise Client Software Binary - Create Account (3) - Create or Modify System Process (4) - Event Triggered Execution (14) - External Remote Services - Hijack Execution Flow (13) - Process Injection (4)	- Abuse Elevation Control Mechanism (4) - Access Token Manipulation (3) - BITS Jobs - Build Image on Host - Debugger Evasion - Deobfuscate/Decode Files or Information - Deploy Container - Direct Volume Access - Domain Policy Modification (3) - Execution Guardrails (3) - Exploitation for Defense Evasion - File and Directory Permissions Modification (3) - Hide Artifacts (13) - Hijack Execution Flow (13) - Process Injection (4) - Process Termination (4)	- Adversary-in-the-Middle (3) - Brute Force (4) - Credentials from Password Stores (3) - Exploitation for Credential Access - Forced Authentication - Forge Web Credentials (3) - Input Capture (4) - Modify Authentication Process (3) - Multi-Factor Authentication interception - Multi-Factor Authentication Request Generation - Network Sniffing	

Attack Operation

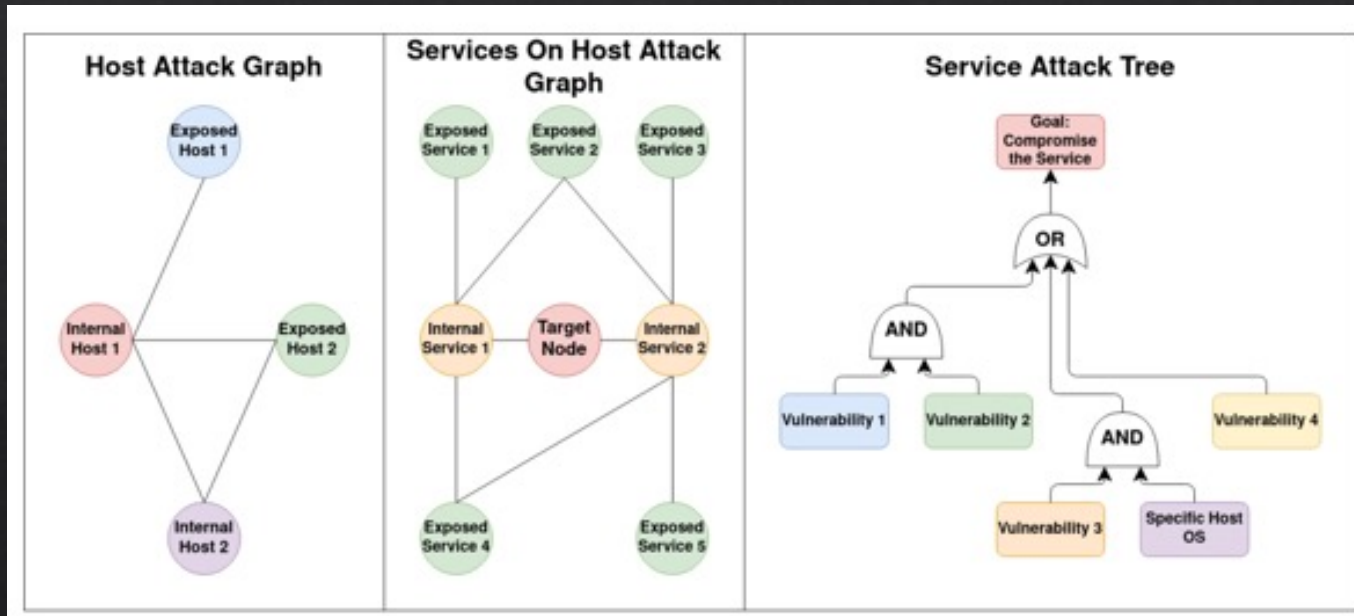


MTD operations

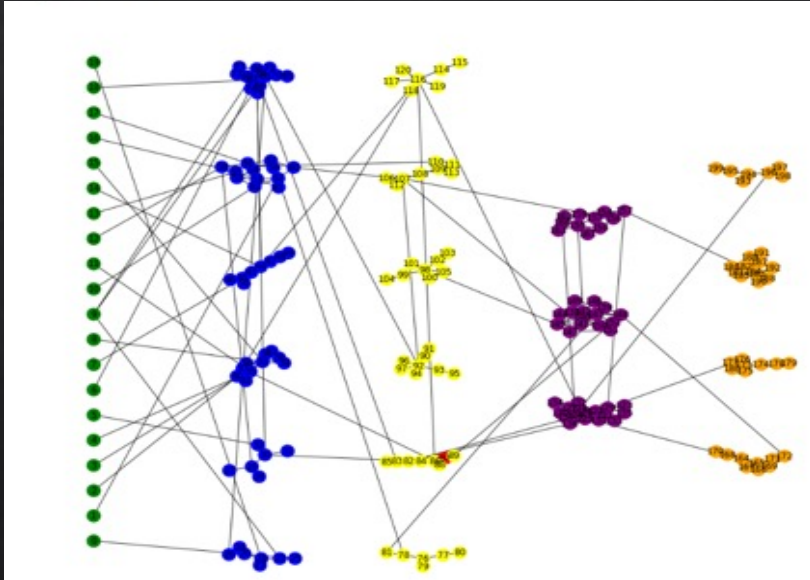
MTD Operation



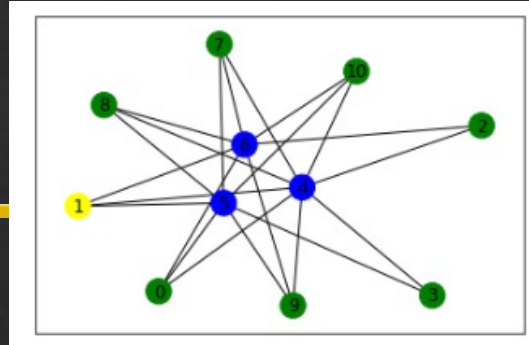
The Model – 3-Layer HARM



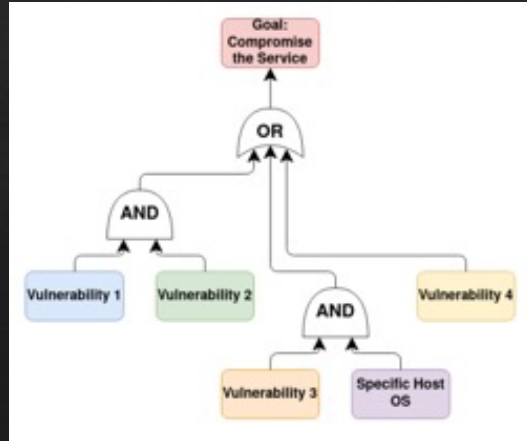
System Modeled



Host Attack Graph - Barabasi-Albert

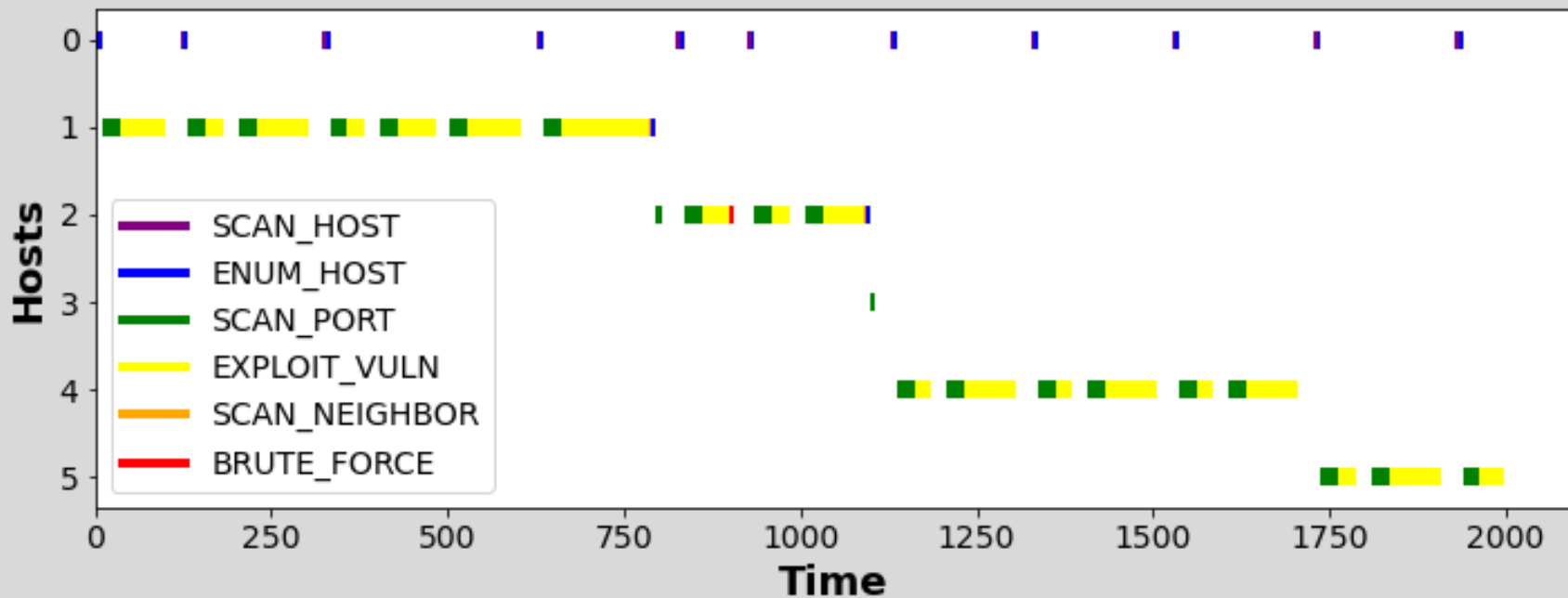


Service Attack Graph – Watts-Strogatz



Vuln Attack Tree – Conditional

Attack operation visualization



Summary

- ◇ There are **various** security standards and frameworks internationally accepted as a common practice
 - ◇ E.g., ISO and NIST security standards and frameworks
- ◇ They provide detailed **procedures** for organisations to follow, in order to assess the security posture of their systems
- ◇ Many steps are involved, so security administrators should ensure that each step is done **carefully and complete**
- ◇ Use of **automated tools** can speed up the process, as well as avoiding any human errors

Additional Items

◇ Security models

- ◇ Kordy, Barbara, Ludovic Piètre-Cambacédès, and Patrick Schweitzer. "DAG-based attack and defense modeling: Don't miss the forest for the attack trees." *Computer science review* 13 (2014): 1-38.
- ◇ Hong, Jin B., et al. "A survey on the usability and practical applications of graphical security models." *Computer Science Review* 26 (2017): 1-16.
- ◇ Visualisation (note: videos are not working): <https://visualisation.trespass-project.eu/>